

Supplementary Material for OTA-Shield: A Hardware-Measured Reference Architecture for In-Network OTA Rollout Admission and Bounded Firmware-Attack Detection in Battery Energy Storage Systems

Philip Akekudaga^a

^aUniversity of Rhode Island, Kingston, RI, USA

ARTICLE INFO

Keywords:
Supplementary material

ABSTRACT

This document provides supplementary figures, tables, and methodological detail supporting the main paper: per-trial results, the first-contact recall taxonomy, build provenance, the statistical methodology, per-component resource placement, and the boundary and capacity floats referenced from the evaluation.

S1. E8 per-trial results

Table S1 reports the raw per-trial outcomes for the 20 E8 stochastic trials summarized in §6.3. Across 20 trials the detector produces $F_1 = 0.9962 \pm 0.0075$ (mean $\pm$ stdev; range [0.9744, 1.0000]), with dispersion concentrated in three trials that miss one to three of 60 attack events. Precision is exactly 1.0 on every trial. These numbers underlie the aggregated 0.996 [0.993, 0.999] result reported in the body; readers who want to assess dispersion directly rather than rely on the bootstrap CI can do so from this table.

Table S1
Per-trial confusion-matrix counts and derived metrics (E8). TP/FN/FP/TN are raw event counts; precision, recall, and F1 are derived per-trial.

Trial	TP	FN	FP	TN	Prec.	Rec.	F1
1	59	1	0	30	1.0000	0.9833	0.9916
2	60	0	0	30	1.0000	1.0000	1.0000
3	60	0	0	30	1.0000	1.0000	1.0000
4	60	0	0	30	1.0000	1.0000	1.0000
5	60	0	0	30	1.0000	1.0000	1.0000
6	60	0	0	30	1.0000	1.0000	1.0000
7	60	0	0	30	1.0000	1.0000	1.0000
8	60	0	0	30	1.0000	1.0000	1.0000
9	57	3	0	30	1.0000	0.9500	0.9744
10	58	2	0	30	1.0000	0.9667	0.9831
11	60	0	0	30	1.0000	1.0000	1.0000
12	58	2	0	30	1.0000	0.9667	0.9831
13	60	0	0	30	1.0000	1.0000	1.0000
14	59	1	0	30	1.0000	0.9833	0.9916
15	60	0	0	30	1.0000	1.0000	1.0000
16	60	0	0	30	1.0000	1.0000	1.0000
17	60	0	0	30	1.0000	1.0000	1.0000
18	60	0	0	30	1.0000	1.0000	1.0000
19	60	0	0	30	1.0000	1.0000	1.0000
20	60	0	0	30	1.0000	1.0000	1.0000
mean	59.55	0.45	0.0	30.0	1.0000	0.9925	0.9962
stdev	0.89	0.89	0.0	0.00	0.0000	0.0148	0.0075

S2. E19' first-contact recall taxonomy

Rollback detection (R6) requires a prior authenticated reference version for the targeted BMS: an attack

packet to a device with no established baseline produces a no-decision (ND) rather than a HOLD, because R6 has no high-water mark to compare against. When a trial's Phase-1 baseline covers fewer devices than the attack set targets, the uncovered devices have no stored version, so attack packets to them generate a parse-level digest rather than a HOLD digest and the controller makes no decision. This is a fundamental property of a version-monotonicity detector, not a tuning artifact. We report two recall framings on the deployed gated build (460 rollback attacks across 20 trials; the detector drops 394 of them):

Framing (i), ND-excluded (lenient). Recall over attack events on devices with an established Phase-1 baseline: $394/406 = 0.970$ (Wilson 95% CI [0.949, 0.983]). This matches the detector's stated operating condition, a BMS whose baseline R6 has already recorded. The 12 reachable misses are rollbacks that reached the controller but were not dropped.

Framing (ii), strict (headline). Counting the 54 first-contact ND events as false negatives: $394/460 = 0.857$ (Wilson 95% CI [0.822, 0.886]). This is the figure we headline, treating any undetected attack packet as a miss regardless of first-contact status, per evaluation-integrity guidance for security detectors [1, 2].

The first-contact ND rate is 54/460. Precision is 1.000 with zero benign false positives across 340 legitimate events (§6.4). The un-gated build's apparent near-perfect recall was an artifact of the `hold_armed_reg` cascade incidentally dropping first-contact rollbacks; on the deployed gated build that cascade is inert (§6.4), so the cold-start misses surface as the gap between strict and lenient recall.

S3. Build provenance and the R5-gating revision

The results in this paper were collected on two successive binaries, and this appendix records which experiment ran on which so that each number can be tied to a fixed configuration. The deployed build gates the fleet-fanout counter (R5) on the unauthorized-source flag (`r2_fired`) and arms the per-source `hold_armed_reg` gate only on R5; because R5 sits behind the terminal R2 drop, that gate is inert on reachable input (§6.4, §7.2). An earlier un-gated build armed the per-source gate on *any* rule fire. On that build a compressed benign rollout that tripped the per-BMS replay rule (R1) would arm the gate and drop the source's subsequent packets at line rate before the arbiter could clear them, producing benign-rollout false positives. Restricting the gate's arming to R5 removes this behavior, and E12, E19, and E19' were re-measured on the deployed build, where they report zero benign-rollout false positives (§6.3, §6.4).

One consequence of the revision is the rollback recall the deployed build reports. The un-gated build recorded a near-perfect rollback recall, but that figure was inflated: the per-source gate incidentally dropped first-contact rollbacks that R6 itself cannot catch, because a first contact to a BMS has no stored version high-water mark. On the deployed build those cold-start cases surface as the gap between strict recall (0.857, counting first-contact events as misses) and lenient recall (0.970); we report the strict figure (§6.4, Appendix S2).

The five-state lifecycle matrix (E22, §7.7) was originally completed only on the un-gated binary, where the per-source gate pre-empt the arbiter (152 of 160 benign rollout events dropped, a 95% false-positive rate). We re-ran the in-scope active-authorized state on the deployed gated build (0 false positives across 80 events, confirming the fix); the remaining states probe off-parameter authorized operation that the gated build does not quarantine (§7.7), and a containment matrix that also exercises a per-source hold role would require the 5-tuple-indexed hold register of §7.2 behind a P4 recompile. The integrity and freshness lifecycle failure modes are covered by E12b (§6.3). Table S2 summarizes the per-experiment configuration.

The override table is 5-tuple-keyed on the deployed build throughout (§6.7); E13 additionally characterizes the optional source-IP aggregation variant. E7b was re-run on the deployed gated build (§6.5): over the 8 h trace it records 0 benign false positives and catches all 100 rollback attacks, so it now reports on the deployed binary rather than an un-gated auxiliary run.

S4. Statistical methodology

Deterministic experiments (E1, E4, E5, E6) repeat a fixed computation and are reported without CIs. Stochastic experiments report 95% CIs from a trial-level percentile bootstrap: per-trial point estimates are

Table S2

Per-experiment build provenance. “Deployed gated” is the final binary (R5 r2-gated, per-source hold gate inert, 5-tuple-keyed override table); “un-gated” is the earlier binary used before the R5-gating revision. The last column marks whether the result is part of the deployed-build story or is auxiliary/motivating only.

Experiment(s)	Binary	R5 gating	Deployed story
E1, E2, E6, E8, E14	deployed gated	r2-gated	yes
E4 (arbiter ablation)	deployed gated	r2-gated	yes
E12, E12b	deployed gated	r2-gated	yes
E19, E19'	deployed gated	r2-gated	yes
E9, E21, E23, E20	deployed gated	r2-gated	yes
E10 (incl. symmetric)	deployed gated	r2-gated	yes
E11, E13, E18	deployed gated	r2-gated	yes
E7b (long-horizon)	deployed gated	r2-gated	yes
S1, S2 (200-BMS)	earlier binary	n/a	scope only (cap-limited)
E22 active-authorized	deployed gated	r2-gated	yes (confirms fix)
E22 full matrix	un-gated	ungated	motivating only

resampled with replacement over the n trials ($B = 2000$ replicates, $\alpha = 0.05$); a degenerate resample distribution (all trials identical) is reported as the point estimate with the Clopper–Pearson one-sided bound instead. For E8 precision, $FP = 0$ across 20 trials / 600 benign events, so the bootstrap CI compresses to $[1.000, 1.000]$ and is replaced by the Clopper–Pearson 95% upper bound $\leq 0.50\%$ ($= 3/600$); E12 uses $\leq 0.67\%$. These are correctness runs, not independent significance tests, so a Bonferroni correction is inappropriate.

E19' (20 trials, 800 events: 460 rollback attacks, 340 legitimate) yields zero benign false positives (precision 1.000, Wilson 95% CI $[0.990, 1.000]$). Its between-trial variance lives in recall, because a stochastic share of rollbacks are first-contact events R6 cannot catch on a version it has never seen (§6.4): strict recall counts them (0.857, Wilson 95% CI $[0.822, 0.886]$), the lenient figure excludes them (0.970).

To guard against the inflated-score failure mode of learned ICS detectors [3], the benign test set contains unusual but legitimate events (emergency hotfix repushes, mid-rollout source migration, delayed-retry bursts, an authorized fleet rollback in E12), and the adversarial sweeps (E9, E21, E23, E20) probe variants the rules were not tuned against. The zero-FP bounds are event-count based; benign captures span roughly 3.5 min (E8, 600 events) and 25 min (E12, 450 events) plus the E12b soak. A multi-hour production soak [4] is future work.

S5. Per-component resource placement

S6. Supplementary figures and tables

References

- [1] Feargus Pendlebury, Fabio Pierazzi, Roberto Jordaney, Johannes Kinder, and Lorenzo Cavallaro. TESSERACT: Eliminating experimental bias in malware classification across space and time. In *28th USENIX Security Symposium*

Table S3

Per-component data-plane resource placement, extracted from the deployed build's compiler output (the `context.json/BFA` of the binary loaded by `bf_switchd`). The pipeline occupies all 12 ingress MAU stages. "Largest match table" gives the dominant logical table per component and its entry count; "Stateful registers" lists the SALU-backed memory. Exact chip-relative SRAM/TCAM percentages require the compiler's MAU resource log, which was not retained for the deployed binary; we therefore report the authoritative allocation counts.

Component	Stage(s)	Largest match table (entries)	Stateful registers (entries)
Parsing + topic match	0	topic_prefix (8)	—
Session manager	0–1	session_id (64 K)	session_bytes (64 K), first_ts (64 K), coarse_time (1)
R2 unauthorized source	1	r2_authorized_sources (16)	—
R5 fleet fanout	1–6	fleet_monitor (64 K)	bf_r0/r1/r2 (3×1024), r5_count (1)
BMS index map	5	bms_ip_to_idx (128)	—
R4 oversize	5–6	r4_threshold (range)	shares session_bytes
R1 replay	6–7	secondary_rules (256)	r1_last_seen (256)
R6 rollback	6	rule_r6_rollback (256)	r6_bms_max_version (256)
Policy engine	7–8	set_src_idx (256)	—
Override + hold cascade	9–10	session_action_override (256, 5-tuple)	hold_armed (256)
Deparser digests	11	6× learn-quantum digests	—

Whole pipeline: 12 of 12 ingress stages; 76 PHV containers (23×8 b, 25×16 b, 28×32 b); 14 SALU units; 10 TCAM blocks; 10 map RAMs.

Table S4

Rollout-Authorization Table fields. The manifest is a per-rollout JSON object loaded by the controller; a HOLD packet passes only when every condition matches.

Field	Policy semantics
authorized_source_ips	Allow-list of IPv4 addresses permitted to originate firmware PUBLISHes for this rollout.
target_bms_list	Allow-list of destination BMS IPs within scope of the rollout.
valid_window_start/end	UTC wall-clock window during which the rollout is active.
expected_payload_size_range	Inclusive byte range for advertised firmware size.
expected_firmware_version	Version number reported in the OTA header for control-plane sanity check.
max_concurrent_targets	Enforced per-rollout cap on the number of concurrent active sessions a rollout may hold; the controller denies admission beyond it (0 = unlimited).
rollback_window	Optional {min_version, max_version} pair authorizing a rollback range for this rollout (see §4.4.2). Default-absent: R6 remains a terminal rule.

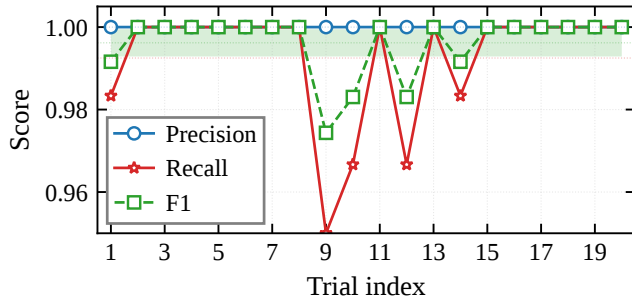


Figure S1: Per-trial precision, recall, and F_1 across the 20 stochastic E8 trials, with the F_1 bootstrap 95% CI band shaded. The narrow dispersion shows that stochastic performance stays close to the CI interval reported for E8 in Table 6.

Table S5

Reference-channel parser portability (E18) across the 8-variant MQTT-parameter sweep on the deployed parser. PARSED = the parser extracted a valid OTA header; PARSER-MISS = the packet was classified as non-OTA and forwarded unflagged. No variant is dropped; the determining factor is the 32-byte topic slot, not QoS or the retain flag.

Variant	Parameters	Outcome
baseline	topic=32 B, QoS=1, retain=0	PARSED
QoS=2	topic=32 B, QoS=2, retain=0	PARSED
retain=1	topic=32 B, QoS=1, retain=1	PARSED
QoS=0	topic=32 B, QoS=0, retain=0	PARSED
short topic	topic=16 B, QoS=1, retain=0	PARSER-MISS
long topic	topic=64 B, QoS=1, retain=0	PARSER-MISS
QoS=0, short	topic=16 B, QoS=0, retain=0	PARSER-MISS
QoS=0, long	topic=64 B, QoS=0, retain=0	PARSER-MISS

(USENIX Security 19), pages 729–746. USENIX Association, 2019. URL <https://www.usenix.org/conference/usenixsecurity19/presentation/pendlebury>.

- [2] Daniel Arp, Erwin Quiring, Feargus Pendlebury, Alexander Warnecke, Fabio Pierazzi, Christian Wressnegger, Lorenzo Cavallaro, and Konrad Rieck. Dos and don'ts of machine learning in computer security. In *31st USENIX Security Symposium (USENIX Security 22)*, pages 3971–3988. USENIX Association, 2022. URL <https://www.usenix.org/conference/usenixsecurity22/presentation/arp>.

- [3] Dominik Kus, Eric Wagner, Jan Pennekamp, Konrad Wolsing, Ina Berenice Fink, Markus Dahlmanns, Klaus Wehrle, and Martin Henze. A false sense of security? revisiting the state of machine learning-based industrial intrusion detection. In *Proceedings of the 8th ACM Cyber-Physical System Security Workshop (CPSS)*, pages 73–84. ACM, 2022. doi: 10.1145/3494107.3522773.

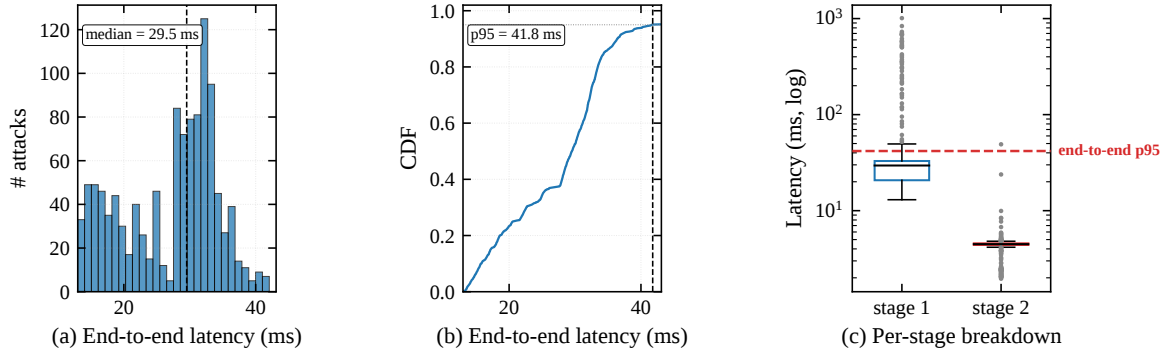


Figure S2: End-to-end detection latency on 1200 attack events from the stochastic experiment: (a) histogram, (b) empirical CDF, (c) per-stage box plot on log scale. Stage 1 = send $\rightarrow$ digest arrival (generator + Tofino 1 pipeline + gRPC transport); stage 2 = digest arrival $\rightarrow$ controller decision (Python arbitration); end-to-end = stage 1 + stage 2. Medians 29.5/4.5/34.0 ms; p95 values 41.8/4.8/46.6 ms. Latency is restricted to attack events because the benign workload interposes inter-trial state-reset barriers (~ 2.7 s) between trials; those barriers are driver-side synchronization, not per-event detection latency, so pooling them would overstate the on-path tail.

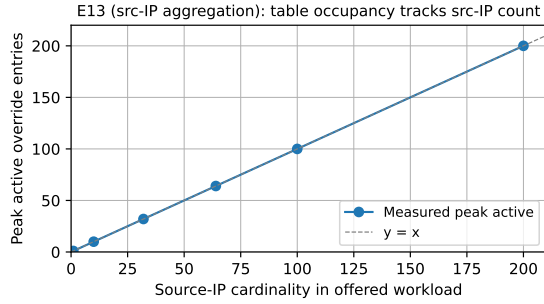


Figure S3: Override-table occupancy under source-IP aggregation (E13). Peak active override-table entries versus offered source-IP cardinality at 500 pps per window, averaged over a 5 s TTL. Measurements fall exactly on $y = x$: one table entry per distinct source IP, independent of 5-tuple fanout. Zero installs are rejected up to 200 source IPs in our deployment pipeline.

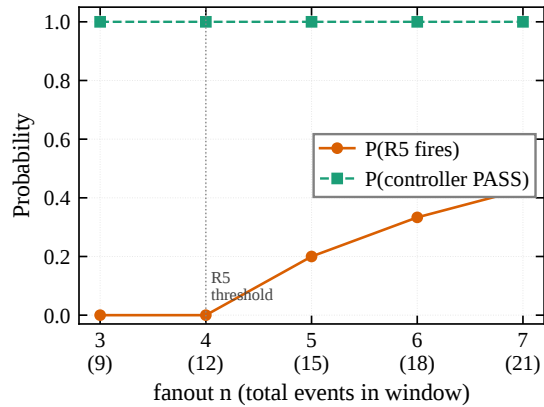


Figure S4: R5 sensitivity as a function of fanout size: $P(R5 \text{ fires})$ grows linearly above threshold 4, characterizing the rule's intrinsic counter. On the deployed build R5's counter is r2-gated, so an authorized fanout never fires R5 (§6.4); the authorized-rollout PASS rate is 1.0 trivially, with no R5 fire to demote.

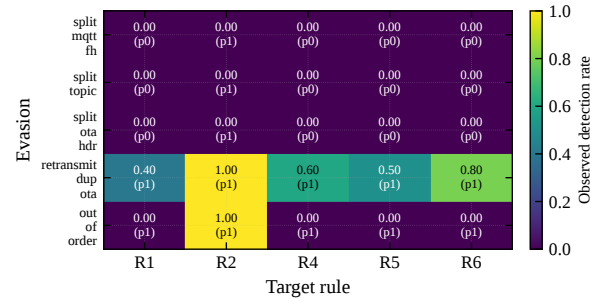


Figure S5: TCP-segmentation evasion (E23): observed per-cell drop rate over 10 trials/cell (250 trials), each cell reset-isolated; cell text is observed rate (predicted in parens). Header-split evasions defeat every rule including the source-keyed R2; only retransmit-dup (intact PUBLISH on the wire) yields parse-dependent detection, and only probabilistically. The R5 column does not exercise genuine fanout (single-PUBLISH base attack) and is shown for completeness.

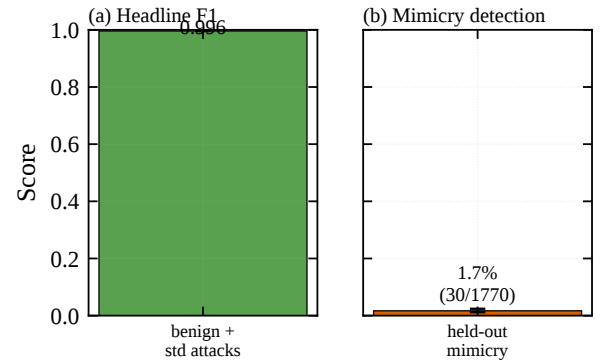


Figure S6: The two headline numbers, shown co-equal on a common $[0, 1]$ scale: (a) naive fleet-fanout detection $F_1 = 0.996$ (E8) versus (b) adaptive-mimicry coverage 1.7% (E21). The headline applies to the designed naive family; an adversary who reshapes cadence faces the right-hand number.

Table S6

50-BMS vs. 200-BMS precision and F_1 . Recall is 1.000 across the 200-BMS replays (S1, S2); the 50-BMS E8 row reflects nine near-threshold R1 misses (recall 0.992). No rollback attempt is missed at either scale. The precision collapse at 200-BMS is attributed to the 64-entry controller/manifest BMS cap. The data-plane `bms_ip_to_idx` table is itself compiled at 128 entries (Table S3), so legitimate packets addressed to BMS 65–200 are unmapped and take the fail-closed DROP path.

Experiment	Fleet	Precision	Recall	F_1
E8 (50-BMS headline)	50	1.000	0.992	0.996
S1 (200-BMS, det.)	200	0.195	1.000	0.327
S2 (200-BMS, stoch.)	200	0.292	1.000	0.453

Table S7

CPU IDS baselines on identical traffic (E10), on the E1 PCAP replay (90 events: 60 attack + 30 legitimate). Variants (i)–(iv) are CPU-IDS configurations; variants (v) and (vi) post-process variants (i) and (iii)'s alerts respectively through the same RAT arbiter OTA-Shield uses in-band (the apples-to-apples controls).

Variant	Prec.	Recall	Acc.	TP	FP
(i) Suricata min-effort	N/A	0.000	0.333	0	0
(ii) Suricata stateful	0.691	0.783	0.622	47	21
(iii) Suricata permissive	0.667	1.000	0.667	60	30
(iv) Zeek domain-aware	0.698	1.000	0.711	60	26
(v) Suricata + RAT	N/A	0.000	0.333	0	0
(vi) Suricata permissive + RAT	1.000	0.500	0.667	30	0

- [4] Marco Caselli, Emmanuele Zambon, and Frank Kargl. Sequence-aware intrusion detection in industrial control systems. In *Proceedings of the 1st ACM Workshop on Cyber-Physical System Security (CPSS)*, pages 13–24. ACM, 2015. doi: 10.1145/2732198.2732200.
- [5] Qinwen Hu, Se-Young Yu, and Muhammad Rizwan Asghar. Analysing performance issues of open-source intrusion detection systems in high-speed networks. *Journal of Information Security and Applications*, 51:102426, 2020. doi: 10.1016/j.jisa.2019.102426. URL <https://doi.org/10.1016/j.jisa.2019.102426>. Quantifies Snort/Suricata drop behavior at 1–40 Gbps; AF_Packet reaches 60 Gbps before collapse.

Table S8

Defence-in-depth coverage. Each layer catches a different fraction of the attack space; OTA-Shield is one of the three, not a replacement for the others.

Layer	What it catches
Endpoint signing (SUIT/Uptane)	Unsigned or mis-signed firmware at the BMS, regardless of how it arrives. Blind to <i>signed-but-malicious</i> firmware (stolen signing key) and blind to in-transit fanout.
OTA-Shield data plane	Naive coordinated campaigns (A1–A4 at their designed thresholds, plus A5 rollback via R6 and Gate B) at the network aggregation point. Blind to shaped adversaries that stay inside rule blind zones (E21); requires placement after TLS/VPN termination (§7).
Operator rollout dashboard	Slow-drift campaigns visible over hours to days through fleet-version skew. Too slow to stop a minutes-scale attack in flight.

Table S9

Rule fires per mimicry strategy (E21) under per-strategy isolation, summed over 30 campaigns (1770 attack events total). Each strategy is designed to evade a specific data-plane rule; “caught” counts events the controller dropped, “missed” counts everything else. Under isolation, only *R1-late* produces any drop; every sub-threshold strategy evades entirely. Missed events escape the data plane and would need control-plane or endpoint recovery.

Strategy	N	R1	R2	R4	R5	caught	missed
fanout-sub	720	0	0	0	0	0	720
fanout-three	540	0	0	0	0	0	540
R4-deadzone	90	0	0	0	0	0	90
combined	360	0	0	0	0	0	360
R1-late	60	30	0	0	0	30	30
Total	1770	30	0	0	0	30	1740

Table S10

Tofino resource footprint of the evaluated build, with rough comparison to a CPU-based alternative on the same traffic. Dollar-per-BMS-year assumes a five-year amortization of a USD 20 k switch over a 50-unit fleet.

Cost dimension	OTA-Shield (Tofino 1)	Suricata (Xeon Gold)
MAU stages used	12 of 12 (Table S3)	n/a
SRAM for rule state	3 KB (R5 Bloom) + 0.5 KB (R1)	host RAM
Session table (fleet-wide)	512 KB (two 64 K × 32 bit)	host RAM
Power per Gb/s (amortized)	~70 mW/Gb/s	~5 W/Gb/s
Throughput headroom	measured 2,200 pps (generator-bound); ASIC 25 Gb/s link, unmeasured	40–60 Gb/s [5]
Hardware cost (list)	\$20 k (32 × 100 GbE)	\$8–12 k server
\$/BMS-year (50-unit fleet)	≈\$80	≈\$40